

TryHackMe — Introduction to Cyber Security Path

Operating System Security

Learning Notes — CIA Triad, Authentication, Weak Passwords, File Permissions, Malware & SSH Lab

"Security protects against attacks on confidentiality (keeping your data secret), integrity (ensuring your data is unaltered), and availability (making sure your data is accessible when needed)."

 CIA Triad	 Authentication	 Weak Passwords	 File Permissions	 Malware	 SSH Lab
---	--	--	--	---	---

1. What Is an Operating System?

Every day you use a smartphone, laptop, or any type of computer — you interact directly or indirectly with an operating system. The OS is the critical software layer that sits between the hardware and the applications you run. Programs like web browsers (Firefox, Chrome), messaging apps (Signal, WhatsApp), and email clients (Thunderbird) run on top of the OS, not directly on hardware.

Room Answer: Which of the following is NOT an operating system?

Thunderbird — it is an email client application (made by Mozilla), not an operating system. The operating systems listed in the room include MS Windows, macOS, iOS, Android, Chrome OS, and Linux. Thunderbird runs ON an OS but is not one itself.

1.1 Why OS Security Matters

The OS is the most critical software layer on any device. If the OS is compromised, every application running on it — and all the data it processes — is at risk. OS security is therefore the foundation of all other security controls. Three categories of weakness are specifically targeted by attackers in this room:

Vulnerability Category	What It Means
------------------------	---------------

1. Weak Passwords	Easy-to-guess or commonly used passwords allow attackers to gain unauthorised access to accounts through brute force or simple guessing.
2. Poor File Permissions	Overly permissive file access allows attackers (or malicious programs) to read confidential data or modify files they should not be able to access.
3. Malicious Programs	Malware (trojans, ransomware, spyware) installed through deception or exploits compromises the confidentiality, integrity, or availability of the system.

2. The CIA Triad — What Security Protects

All of OS security is ultimately about protecting three fundamental properties of data and systems. These three properties are collectively known as the CIA Triad — the cornerstone framework of information security.

Letter	Property	Definition	Example Attack
C	Confidentiality	Keeping data secret — only authorised parties can access it.	Weak password → attacker reads private messages/files.
I	Integrity	Ensuring data is unaltered — it has not been modified without authorisation.	Poor file permissions → attacker modifies configuration or log files.
A	Availability	Making data accessible when needed — systems must be operational.	Ransomware encrypts files → data unavailable without ransom payment.

3. Authentication — Proving Who You Are

Authentication is the act of verifying your identity — for both local systems (logging into your laptop) and remote systems (SSH into a server). It is the gateway through which all access is controlled. If authentication is bypassed or broken, every security control behind it is at risk.

3.1 The Three Authentication Factors

Factor	Category	Examples	Strength
Factor 1	Something you know	Password, PIN, passphrase, security questions	Weakest — can be guessed, stolen, or forgotten

Factor 2	Something you are	Fingerprint, face ID, iris scan, voice recognition	Strong — biometrics are unique and hard to fake
Factor 3	Something you have	Phone (SMS/OTP), hardware token, smart card, authenticator app	Strong — requires physical possession

Multi-Factor Authentication (MFA)

MFA combines two or more of these factors. Even if an attacker steals your password (Factor 1 compromised), they still cannot authenticate without your phone (Factor 3). MFA is the single most effective control against account takeover attacks. All critical accounts — email, banking, VPN, admin systems — should have MFA enabled.

3.2 Why Passwords Are the Most Attacked Factor

Since passwords (Something you know) are the most common authentication method, they are also the most attacked. The main weaknesses that attackers exploit:

- Easy-to-guess passwords — using predictable words, phrases, or patterns.
- Password reuse — the same password on many websites. One breach exposes all accounts.
- Personal details — date of birth, pet name, family member. Attackers research targets on social media.
- Common passwords — millions of users choose from the same small set of predictable passwords.

4. Weak Passwords — The NCSC Top 20 List

The UK National Cyber Security Centre (NCSC) published a list of the 100,000 most commonly used passwords — all of which should be considered compromised and never used. Here are the Top 20 most common passwords that appear in breach databases. Every attacker knows this list and will try these first:

#	Password	#	Password	#	Password	#	Password
1	123456	6	12345	11	1234567890	16	dragon
2	password	7	abc123	12	000000	17	master
3	12345678	8	monkey	13	iloveyou	18	123123
4	qwerty	9	1234567	14	admin	19	welcome
5	123456789	10	sunshine	15	letmein	20	login

Lab Password #7 — abc123

Johnny's password is abc123 — number 7 in the NCSC top 20 list. Sammie's password dragon is number 16. Both are in the top 20 most commonly used passwords and are therefore known to every attacker. The lab demonstrates how quickly accounts with common passwords can be compromised by systematic attempts.

4.1 What Makes a Password Strong?

The room also tests understanding of what constitutes a strong password. The answer LearnM00r is a strong password because it is NOT in the common password list and contains a mix of uppercase, lowercase, numbers, and is not an obvious word:

Feature	Weak Password	Strong Password
Length	Short — 6 to 8 characters	Long — 12+ characters
Character types	Letters only, or numbers only	Mix of uppercase, lowercase, numbers, symbols
Predictability	Dictionary word, name, keyboard pattern	Random or passphrase — no recognisable pattern
Uniqueness	Reused across multiple sites	Unique to each account
Common patterns	Sequences (123, abc), repetition (000)	No sequences or repeated characters
Personal info	Birthdate, pet name, family member	No connection to personal information

Room Answer: Which is NOT a weak password?

LearnM00r — this contains uppercase and lowercase letters plus a number substitution (0 for o), is not a common word, and does not appear in standard password lists. All the others in the list (from the top 20) are weak.

5. The Three Vulnerability Types — Deep Dive

**Vulnerability 1 — Weak Passwords** — The most targeted authentication weakness**How it is exploited:**

- Guessing attack — manually or automatically trying common passwords from lists like the NCSC top 100,000.

- Dictionary attack — trying every word in a wordlist (rockyou.txt has 14 million passwords).
- Brute force — trying every possible combination. Feasible for short/simple passwords.
- Credential stuffing — using credentials leaked from one breach to attack other services (exploiting password reuse).
- Social engineering — tricking users into revealing passwords via phishing, pretexting, or vishing.
- Password spraying — trying one or two common passwords against many accounts to avoid lockouts.

Real-world impact:

- An attacker gains access to an email account and resets passwords for banking, social media, and other linked accounts.
- Corporate credentials in a breach database are used to access a VPN — enabling network infiltration.
- An admin account with the password 'admin123' is compromised, granting full system access.

Defences:

- Use long, unique, random passwords for every account — a password manager makes this practical.
- Never reuse passwords across sites — one breach should not compromise everything.
- Enable MFA on all critical accounts — especially email, which is the key to all other accounts.
- Never use personal information (name, birthday, pet) in passwords.
- Use a password manager (Bitwarden, 1Password, KeePass) to generate and store strong passwords.

Vulnerability 2 — Poor File Permissions — Misconfigured access controls that expose or allow modification of sensitive data

How it is exploited:

- World-readable sensitive files — configuration files with credentials readable by any user.
- World-writable scripts — cron jobs or startup scripts that any user can modify to inject commands.
- SUID binaries — executable files owned by root but runnable by anyone, passing root privileges to the runner.
- Improperly shared directories — network shares or directories with insufficient access controls.
- Principle of least privilege violations — users given more permissions than their role requires.

Real-world impact:

- An attacker reads /etc/shadow (password hashes) from a misconfigured system and cracks passwords offline.
- A malicious insider modifies a world-writable backup script that runs as root, gaining root access.
- A web application's configuration file (with database password) is readable by all users — credentials stolen.

Defences:

- Apply the principle of least privilege — grant only the minimum permissions needed for each task.

- On Linux: `chmod 600` for sensitive files (owner read/write only). `chmod 755` for scripts.
- Regularly audit file permissions: `find / -perm /o+w` to find world-writable files.
- Remove SUID bit from binaries that do not require it: `chmod u-s binary`.
- Use access control lists (ACLs) for fine-grained permission management beyond basic user/group/other.

Vulnerability 3 — Malicious Programs (Malware) — Software designed to damage, disrupt, or gain unauthorised access

How it is exploited:

- Users are tricked into installing malware via phishing emails, fake downloads, or social engineering.
- Trojan horses appear as legitimate software — once installed, they create a backdoor for remote access.
- Ransomware encrypts files and demands payment for decryption — targeting the Availability of the CIA triad.
- Spyware silently monitors user activity, capturing keystrokes, screenshots, and credentials.
- Worms spread automatically across networks — exploiting OS vulnerabilities without user interaction.

Real-world impact:

- A trojan installed via a fake game download gives attackers remote shell access to read and modify all files.
- Ransomware encrypts a hospital's patient records — encrypted files become gibberish without the decryption key. Availability of critical medical data is destroyed.
- A keylogger captures banking credentials entered on the keyboard — funds stolen from the account.

Defences:

- Install and keep antivirus/antimalware software updated (Windows Defender, ClamAV on Linux).
- Keep the OS and all software updated — patches close vulnerabilities malware exploits.
- Never install software from untrusted sources — only official repositories and verified publishers.
- Regular backups (offline/offline) protect against ransomware — restore from backup instead of paying ransom.
- Use email filtering and browser security extensions to block known malicious links and attachments.

6. Practical Lab — SSH Attack & Privilege Escalation

The hands-on lab demonstrates a real attack chain: use a known weak password to SSH into a Linux server as Sammie, find Johnny's password from the NCSC top 20 list, use bash history to discover the root password that Johnny accidentally typed, and then escalate to root to read the flag.

Lab Setup

Start the AttackBox and the Target Machine. The AttackBox is your attack computer. The target is a Linux server running SSH on port 22. Sammie's password was found on a sticky note near the computer (dragon — #16 in the top 20 list). This represents the real-world risk of physically writing passwords on paper.

6.1 Step 1 — SSH into Sammie's Account

```
# Connect to the target as sammie using SSH
# Password: dragon (found on sticky note — #16 in NCSC top 20 list)
$ ssh sammie@10.10.X.X
sammie@10.10.X.X password: dragon

# Successfully logged in as Sammie
sammie@ip-10-10-X-X:~$

# We are now inside the target Linux system as user 'sammie'
# But Sammie has limited privileges — we need to escalate
```

6.2 Step 2 — Guess Johnny's Password (Top 7 List)

The task says 'based on the top 7 passwords, find Johnny's password.' Go through the list systematically using su (switch user) from inside Sammie's session:

```
# Try passwords from the NCSC top 7 list:
# 1. 123456 2. password 3. 12345678 4. qwerty
# 5. 123456789 6. 12345 7. abc123 <-- this is the one!

# Switch to Johnny's account:
sammie@ip-10-10-X-X:~$ su - johnny
Password: abc123

# Success! Logged in as Johnny
johnny@ip-10-10-X-X:~$

# Johnny's password = abc123 (number 7 in the top 20 list)
```

6.3 Step 3 — Find Root Password in History

The task says: 'Johnny accidentally typed the root password instead of a command.' This is a very common real-world mistake — users confuse the terminal for a password prompt and type their password as a visible command instead. Check bash history:

```
# Check bash command history as Johnny
johnny@ip-10-10-X-X:~$ history
 1  ls
 2  cd Documents
 3  happyHack!NG
 4  su - root
 5  exit

# Line 3 shows the root password accidentally typed as a command!
# Root password = happyHack!NG

# Note: happyHack!NG is NOT in the top 20 list — it is a strong password
# But it was exposed by accident in the command history
```

6.4 Step 4 — Escalate to Root & Capture the Flag

```
# Switch to root account using discovered password
johnny@ip-10-10-X-X:~$ su - root
Password: happyHack!NG

# Root shell achieved!
root@ip-10-10-X-X:~#

# Read the flag from the root directory
root@ip-10-10-X-X:~# cat /root/flag.txt
THM{YouGotRoot}

# Complete control of the system achieved through:
# 1. Weak password (dragon) → gained access as Sammie
# 2. Common password (abc123) → gained access as Johnny
# 3. Command history exposure → revealed root password
# 4. su - root → privilege escalation to full system control
```

Attack Chain Summary

This lab demonstrates a complete attack chain using only two vulnerabilities from the NCSC top 20 password list, plus the classic mistake of accidentally revealing a password in

command history. No exploits, no special tools — just weak passwords and poor operational security. This is how a significant proportion of real-world breaches actually occur.

7. SSH — Secure Shell Protocol

SSH (Secure Shell) is the protocol used in this lab to remotely connect to the Linux server. It is the industry standard for encrypted remote command-line access, replacing the insecure Telnet protocol.

SSH Feature	Detail
Port	Default port 22 (TCP). Commonly changed to a non-standard port to reduce automated attacks.
Encryption	All traffic is encrypted end-to-end — credentials and data cannot be intercepted in transit.
Authentication	Supports password authentication AND public key authentication (much more secure).
Public key auth	Client has a private key; server has the public key. Authentication without sending a password over the network.
Usage	ssh username@hostname_or_IP — connect to a remote system. -p flag specifies a non-standard port.
su command	su - username — Switch User: change to another user account within the same session. su - root elevates to root.
history command	Shows all previously run commands in the session. A goldmine for both defenders and attackers.

Security Note — SSH Best Practices

Disable password authentication on public SSH servers — use key-based authentication only. Change the default port from 22 to reduce automated scanning. Use fail2ban to block IPs after repeated failed login attempts. Never SSH as root directly — SSH as a normal user, then sudo or su to root. Monitor /var/log/auth.log for failed SSH attempts.

8. Room Answers — Quick Reference

Question	Answer
Which of the following is NOT an operating system?	Thunderbird

Which of the following is NOT a weak password?	LearnM00r
What is the password for the user johnny? (from top 7 list)	abc123
What is the root password? (found in bash history)	happyHack!NG
What is the content of the file /root/flag.txt?	THM{YouGotRoot}
Authentication via fingerprint is which factor?	Something you are
Authentication via password is which factor?	Something you know
Authentication via SMS/phone is which factor?	Something you have

9. Lessons from the Lab — What Went Wrong

The lab attack chain exploited multiple security failures simultaneously. Understanding what went wrong — and what should have been done — is the core lesson of the room:

What Went Wrong	The Attack It Enabled	What Should Have Been Done
Sammie used 'dragon' — #16 in the NCSC top 20 list	Attacker SSH'd in as Sammie in seconds	Use a unique, strong password not in any common list
Sammie's password was written on a sticky note	Physical eavesdropper can immediately gain access	Use a password manager — never write passwords down
Johnny used 'abc123' — #7 in the NCSC top 20 list	Attacker switched to Johnny's account trivially	Use a unique, strong password — enable MFA
Johnny typed the root password as a terminal command	Root password exposed permanently in bash history	HISTCONTROL=ignorespace — precede sensitive commands with a space to exclude from history. Or clear history.
The root password was not rotated after potential exposure	Attacker gained root access indefinitely	Regularly audit bash history; rotate exposed credentials immediately
No MFA or account lockout policy was in place	Unlimited password guessing without lockout	Implement fail2ban, MFA, and account lockout after N failed attempts

10. Key Takeaways & Glossary

10.1 Key Takeaways

- OS security protects the CIA Triad: Confidentiality (secrecy), Integrity (unaltered), Availability (accessible).
- An OS is NOT: Thunderbird (an email client). An OS IS: Windows, macOS, iOS, Android, Chrome OS, Linux.
- Three authentication factors: Something you know (password), Something you are (fingerprint), Something you have (phone/OTP).
- Three vulnerability categories: Weak Passwords, Poor File Permissions, Malicious Programs.
- The NCSC top 20 include: 123456, password, 12345678, qwerty, abc123 (Johnny's password, #7), dragon (Sammie's, #16).
- LearnM00r is NOT a weak password — it has mixed case, numbers, and is not in common password lists.
- Lab attack chain: SSH as Sammie (dragon) → su johnny (abc123) → history reveals happyHack!NG → su root → THM{YouGotRoot}
- Bash history records every command — sensitive data accidentally typed as commands is permanently recorded.
- Ransomware encrypts files (making them like gibberish) and demands payment — it attacks Availability.
- Principle of least privilege: users and programs should have only the minimum permissions they need.

10.2 Core Glossary

Term	Definition
CIA Triad	The three pillars of information security: Confidentiality, Integrity, and Availability.
Confidentiality	Keeping data secret — only authorised parties can access it.
Integrity	Ensuring data has not been altered without authorisation.
Availability	Ensuring data and systems are accessible when needed.
Authentication	The process of verifying identity before granting access.
MFA	Multi-Factor Authentication — using two or more authentication factors together.
Malware	Malicious software designed to damage, disrupt, or gain unauthorised access.
Trojan Horse	Malware disguised as legitimate software that creates a backdoor for attackers.
Ransomware	Malware that encrypts files and demands payment for the decryption key. Attacks Availability.
Spyware	Malware that silently monitors and reports user activity, capturing credentials and data.

SSH	Secure Shell — encrypted protocol for remote command-line access (port 22).
su	Switch User — Linux command to change to another user account. su - root elevates to root.
history	Linux command showing all previously run commands in the current shell session.
NCSC	National Cyber Security Centre — UK government agency that published the top 100,000 password list.
Principle of Least Privilege	Security principle: grant users/programs only the minimum permissions required for their task.
Password Reuse	Using the same password on multiple accounts — one breach compromises all.
Credential Stuffing	Using leaked username/password combinations from one breach to attack other services.
Brute Force	Trying every possible password combination until the correct one is found.
Dictionary Attack	Trying passwords from a wordlist (like rockyou.txt) rather than random combinations.
bash history	The file ~/.bash_history that records all commands run in a bash shell. Sensitive data exposure risk.

10.3 Next Steps on TryHackMe

- **Immediate:** Continue with the Network Security room — how attackers target the network layer above the OS.
- **Security:** Complete the Linux Privilege Escalation room — expand on the su/sudo techniques from this lab.
- **Web:** Study the Web Fundamentals path — web applications running on the OS are the most attacked surface.
- **Password:** Take the John the Ripper room — crack password hashes from /etc/shadow using wordlists like rockyou.txt.
- **Forensics:** Work through the Intro to Digital Forensics room — investigate bash history and file evidence.

Simple Attacks Win Most Often

The lab used no exploits, no special tools, and no technical skill — just two passwords from a publicly known top 20 list, and observing a command history mistake. This is the reality of most real-world breaches: simple, preventable mistakes create the entry point. Strong unique passwords, MFA, and awareness of what appears in command history would have prevented the entire attack chain entirely.

Source: TryHackMe — Operating System Security Room | tryhackme.com/room/operatingsystemsecurity